



INTROL: Einführendes Labor Sicherheit

Kursmaterial HS25 - 2025

Florian Wamser & Ron Porath, Hochschule Luzern

16. Oktober 2025

INTROL: Einführendes Labor Sicherheit

Letzte Änderung: 16. Oktober 2025

Begleitendes Kursmaterial des Moduls *INTROL* im Herbstsemester 2025 an der Hochschule Luzern.
Kursmaterial für einen Semesterkurs mit 14 Wochenstunden.



Dieses Skript wird während der Vorlesung angepasst und vervollständigt. Neue Kapitel und Übungen kommen im Verlauf der Vorlesung hinzu.

Autoren

S. Boussaha: Initiale Version und finale Fertigstellung des Dokuments

S. Renggli: Aktualisierung für HS19

R. Bolting: Aktualisierung für HS21

S. Czychi: Anpassungen für aktualisierte Software

Christian Scherrer: Anpassungen an neue OS-Versionen von Kali & Ubuntu, sowie an neues HSLU-CI

bei der MyCampus-Webseite

Dr. Florian Wamser, florian.wamser@hslu.ch

Dr. Ron Porath, ron.porath@hslu.ch

Ideen zum Inhalt und initiales Feedback: Thomas Jösler, S. Boussaha, Peter Infanger

Ausgabe 2025

Erstmalige Durchführung im HS21 (2021).

Studentische Angaben

Bitte tragen Sie im folgenden Feld ihren Namen und Informationen zu ihrem Team ein, falls Sie in einem Team arbeiten.

Team: *

Vorname 1: *

Nachname 1: *

Vorname 2: *

Nachname 2: *

Vorname 3: *

Nachname 3: *

* Je nach Teamgrösse müssen die Felder *Vor-* und *Nachname* in der entsprechenden Anzahl ausgefüllt werden.

Sonstige Angaben und Anmerkungen:

Inhaltsverzeichnis

1	Vorwort	2
1.1	Feedback	2
1.2	Legende	2
2	Labor 4: Man in the Middle (MITM): ARP Request Poisoning und DNS Spoofing	4
2.1	Hintergrundinformationen	9
2.2	Vorbereitung der Labor-Infrastruktur	11
3	ARP Request Poisoning: Senden von gefälschten ARP-Paketen	16
4	DNS Spoofing: Fehlerhafte Domain-Name-System-Einträge im Zwischenspeicher (Cache) des DNS-Resolvers eingeben	27
4.1	Aufsetzen des <i>malicious</i> Webservers	35
4.2	Anpassen der kopierten und malicious Login-Webseite	37

1 Vorwort

1.1 Feedback

Mit Ihrer Mithilfe kann die Qualität des Kurses laufend den Bedürfnissen angepasst und verbessert werden.

Sollte etwas in diesem Kurs nicht wie beschrieben funktionieren, melden Sie dies bitte direkt dem Lehrpersonal oder per E-Mail an Florian Wamser (florian.wamser@hslu.ch).

Bei Problemen wenden Sie sich bitte ebenfalls an das Lehrpersonal.

1.2 Legende

Wichtige Begriffe und Schlüsselwörter sind *kursiv* gedruckt.

Auffällige Unteraussagen im Text sind **fett** gedruckt.

Kommandozeilenbefehle werden durch separate Felder mit grauem Hintergrund hervorgehoben. Zu Beginn einer Zeile sind Kommandozeilenbefehle mit einem > oder \$ gekennzeichnet. Für Referenzierungen wird bei grösseren Blöcken eine Zeilennummer angegeben. Weder das Kommandozeilenzeichen noch die Zeilennummer ist Teil der Eingabe.

```
1 echo "Hello World!"  
2 exit
```

Skriptinhalte oder Inhalte von Konfigurationsdateien werden ebenfalls in separaten Feldern mit grauem Hintergrund angegeben.

```
#!/bin/bash  
echo "Hello, world!"  
echo the $# parameter did not destroy pygments syntax highlighting  
time find . -type f -exec ls -l {} \; | awk '{sum += $5} END {print sum  
}'
```



Anmerkungen und Informationen sind weiterführende Hinweise zu Befehlen oder zu der aktuellen Aufgabe. Sie gelten als ergänzender Hinweis, Notiz oder Hilfestellung.



Dringend beachten. Was hier steht, unbedingt merken oder ausführen. Oft müssen Befehle zwingend für den folgenden Aufgabenteil ausgeführt werden.



Weiterführende Literaturhinweise oder Links. Dies sind Informationen, die nicht zur Ausführung der Versuche benötigt werden, aber bekannt sein sollten.

2 Labor 4: Man in the Middle (MITM): ARP Request Poisoning und DNS Spoofing

Zielsetzung

- Erster Kontakt mit der Linux-Distribution **Kali Linux**, einer beliebten Penetration-Testing-Plattform
- Kennenlernen und Durchführen einer **ARP Request Poisoning**-Attacke
- Tool **Nmap**, als Werkzeug zum Scannen und Auswerten von Hosts in einem Computernetzwerk (**Portscanner**)
- **ARP Request Poisoning** mit **DNS Spoofing**

*Diese Laborübung soll den Studierenden den praktischen Umgang der Protokollanalyse näherbringen. Weiter wird ein erster Kontakt mit der Linux-Distribution **Kali Linux** hergestellt, einer beliebten Penetration-Testing-Plattform. Mit dieser werden Sie im Laufe ihres Studiums immer wieder in Kontakt kommen. Was Sie im Weiteren genau machen, können Sie im nachfolgenden Szenario erfahren.*

Szenario: Sie haben sich in einem lokalen Subnetzwerk (LAN) angemeldet. In diesem Netzwerk sind neben Ihnen noch andere User aktiv. In diesem Szenario sind Sie mit Ihrem PC der Angreifer und andere User potenzielle Opfer. Ihr Ziel ist es, von einem gezielt ausgewählten User die MyCampus-Credentials (Username / Passwort) zu ergattern. Um dieses Ziel zu erreichen, möchten Sie die Loginpage von MyCampus der Hochschule Luzern kopieren, auf einem von Ihnen kontrollierten Webserver anbieten und das Opfer bei einer DNS-Anfrage für **mycampus.hs.lu.ch** auf Ihre «malicious page» umleiten. Umgesetzt wird der Angriff mit ARP Request Poisoning und DNS Spoofing. Das Opfer sollte nicht bemerken, dass es sich auf der falschen Seite befindet, wenn es sich anmeldet. Nach Eingabe der Credentials fangen Sie diese ab und leiten das Opfer auf eine Wartungsseite weiter.

Da auf die WLAN-Sicherheit bei anderen Versuchen eingegangen wird, beschränken wir uns auf drahtgebundenes Ethernet. Der Angriff würde aber grundsätzlich auch in einem WLAN analog stattfinden (und funktionieren...).

Benötigte Mittel / Materialien

Verwenden Sie für diesen Versuch **eine** einzige Labor-Arbeitsstation eines Doppel-Arbeitsplatzes. Ausserdem benötigen Sie folgende Mittel:

- 1x VM: Kali Linux 2025.2 (*integriert in VirtualBox auf der Labor-Workstation*)
 - User: `cisco`
 - Passwort: `cisco`
- 1x VM: Ubuntu 24.04.2 LTS (*integriert in VirtualBox auf der Labor-Workstation*)
 - User: `cisco`
 - Passwort: `cisco`
- 1x ZyXEL ZyWALL USG20-Router (falls vorhanden)



Es sind eine *begrenzte* Anzahl an ZyXEL ZyWALL USG20-Router vorhanden. Falls kein Router mehr für Sie zu Verfügung steht, bauen Sie den Versuch bitte einfach ohne ZyXEL-Router auf. Schliessen Sie `NIC1` direkt an das grüne Labornetzwerk an.



Die **virtuellen Maschinen** auf den Labor-PCs sollten vor Beginn der Bearbeitung der Aufgaben auf ihren Ausgangszustand *zurückgesetzt* werden. Für alle VMs sind Sicherungspunkte (Snapshots) in **VirtualBox** vorhanden, was bedeutet, dass sämtliche VMs in ihren ursprünglichen Zustand zurückgesetzt werden können. Die Sicherungspunkte heissen entweder **fresh** oder **untouched**.

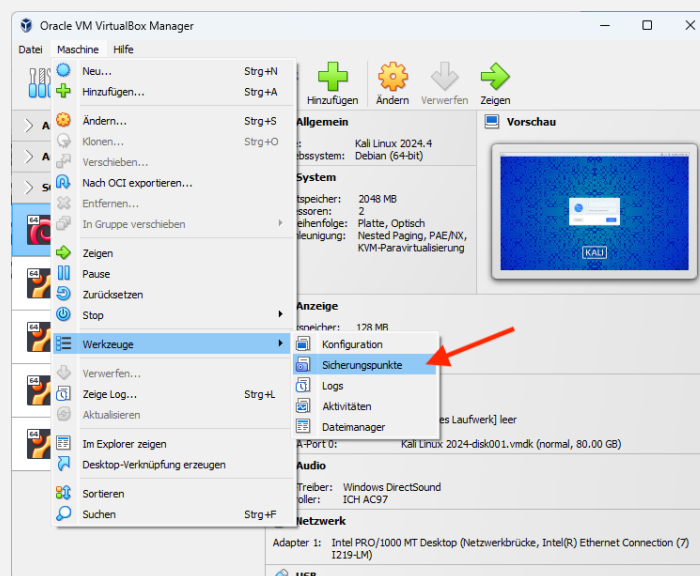


Abbildung 1: Sicherungspunkte in VirtualBox wiederherstellen vor der Bearbeitung der Aufgaben: Ansicht Sicherungspunkte.

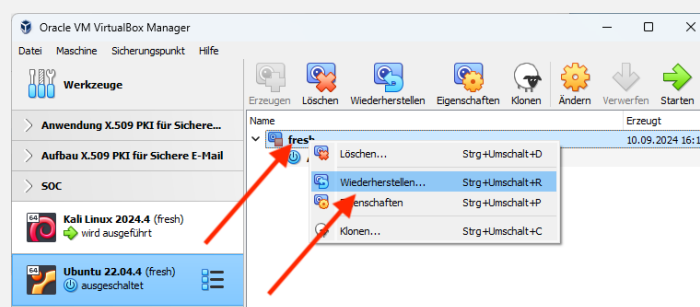


Abbildung 2: Sicherungspunkte in VirtualBox wiederherstellen vor der Bearbeitung der Aufgaben: Wiederherstellung des Ausgangszustands.



Bitte überprüfen Sie an Ihren Arbeitsplätzen sorgfältig, ob alte Einstellungen von vorherigen Übungen, wie beispielsweise der Proxy-Server unter Windows oder die Proxy-Einstellungen in den Browsern **Firefox** oder **Chrome**, *nicht* aktiviert sind. Es kommt häufig vor, dass Studenten die Einstellungen unter Windows vergessen zurückzusetzen.

1. Öffnen Sie die Windows-Einstellungen, indem Sie die Tastenkombination [Windows] + [I] verwenden. Dort klicken Sie dann auf **Network & internet**.
2. Wechseln Sie dann in die Kategorie **Proxy**. Im rechten Teil des Fenster deaktivieren Sie nun die Option **Automatically detect settings** oder **Einstellungen automatisch erkennen**.
3. Unter dem Punkt **Manual proxy setup** klicken Sie auf **Set up** und deaktivieren Sie die Option **Use a proxy server: Off**.

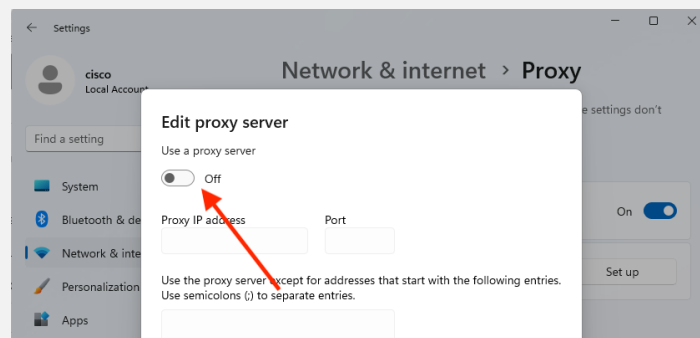


Abbildung 3: Deaktivieren der systemweiten Proxy-Einstellung unter Windows: **Use a proxy server: Off**.



4. Wechseln Sie zum **Mozilla Firefox**. Klicken Sie auf das Burger-Menü mit den drei horizontalen Strichen rechts neben der URL-Eingabemaske. Klicken Sie auf **Einstellungen** → **Allgemein** → **Verbindungseinstellungen** → **Einstellungen...**
Setzen Sie **Kein Proxy** oder **No proxy**.

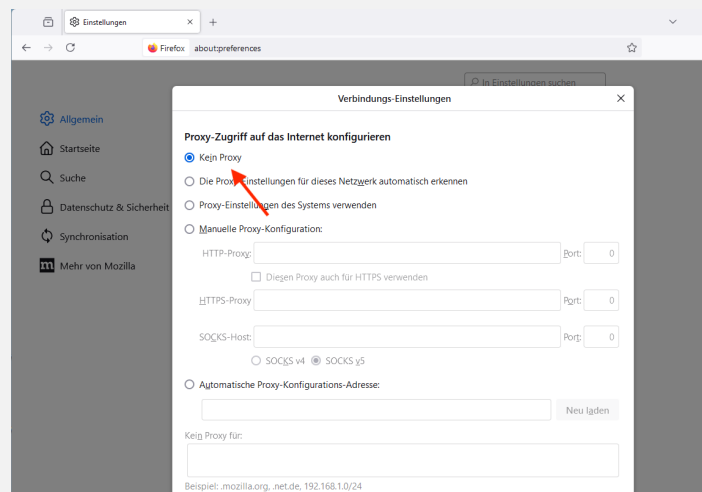


Abbildung 4: Deaktivieren der Proxy-Einstellung für den Browser **Mozilla Firefox**.

2.1 Hintergrundinformationen

Das Konzept **Man in the middle (MITM)** ist ein gängiges Prinzip, das auf verschiedenen Layern angewendet werden kann. Es beschreibt die allgemeine Angriffsform, den Datenverkehr zweier Parteien abzufangen, auszuspähen, potenziell zu manipulieren und weiterzuleiten. Der Angreifer steht dabei entweder physisch oder logisch zwischen den beiden Kommunikationspartnern und hat dabei mit seinem System vollständige Kontrolle über den Datenverkehr zwischen zwei oder mehreren Netzwerkteilnehmern.

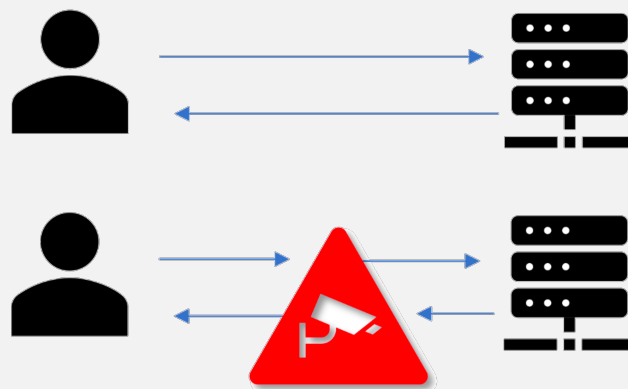


Abbildung 5: Visuelle Darstellung einer MITM-Attacke.

Physical Layer: Beispielsweise könnte sich ein Angreifer im Empfangsbereich eines unverschlüsselten WLAN-Accesspoint als Man-in-the-Middle einschleusen (**Rogue Access Point**). Hierzu emuliert der Angreifer den eigentlichen WLAN-Accesspoint, nimmt Anfragen entgegen und leitet diese danach an den tatsächlichen Accesspoint weiter.

Ethernet Layer (OSI-Layer 2): Ein anderes Beispiel ist das Unterbrechen und Weiterleiten von Ethernet-Verkehr. Hierzu gibt sich der Angreifer durch wiederholtes Senden von ARP-Paketen (**ARP Request Poisoning**) im Netz als ein bestimmter Host aus (beispielsweise als der Router zum Internet) und erhält somit die Pakete auf Ethernet-Layer (Layer 2). Der Angreifer kann die erhaltenen Paketinhalte nun ausspähen und/oder manipulieren, bevor er sie zum eigentlichen Ziel weiterleitet.

Anwendungsschicht (OSI-Layer 7): Auf Anwendungsschicht ist es weiter möglich sich als DNS-Server auszugeben, indem man auf DNS-Anfragen antwortet (**DNS Spoofing**). Sendet ein Client eine DNS-Anfrage und hat ein Angreifer Zugriff auf die Pakete (beispielsweise mittels Zugriffs auf einen Router), kann er DNS-Antworten abhören und weiterleiten. In dieser Übung wird sogar eine eigene DNS-Antwort generiert und der Angreifer gibt sich als DNS-Server aus.

Auch MITM-Attacken auf SSL/HTTPs oder SSH sind populär. Bei SSH gibt sich eine Person als ein Ziel-SSH-Server aus. Das Opfer baut eine SSH-Verbindung mit dem Angreifer statt mit dem eigentlichen Ziel auf. Dadurch kann der Angreifer die Verschlüsselung bestimmen, vorgeben und hat Zugriff auf die SSH-Verbindung. Weiter erhält der Angreifer das Passwort, da er sich als Zielhost ausgibt und die Anmeldedaten vom Opfer erhält. Mit den Anmeldedaten des Opfers meldet sich der Angreifer nun beim Ziel-SSH-Server an und baut eine reguläre SSH-Verbindung auf. Der Angreifer kann somit - unbemerkt vom Opfer - SSH-Befehle mithören, empfangen, an den SSH-Zielserver weiterleiten und reguläre Antworten des Ziel-SSH-Servers zum Opfer zurücksenden. Er hat vollen Zugriff auf die Inhalte der SSH-Verbindung, obwohl diese verschlüsselt sind und erhält die Anmeldedaten des Ziel-SSH-Servers.

Technisch gesehen ist die Durchführung eines erfolgreichen MITM-Angriffs ziemlich komplex. Ausgeklügelte Tools für deren Durchführung sind jedoch leicht verfügbar, sowohl für Hacker als auch für Penetrationstests. Beispielsweise unterstützt das Penetrationstest-Tool [Metasploit](#) viele Arten von MITM-Angriffen, und Tools wie [Armitage](#) bieten eine einfach zu bedienende grafische Benutzeroberfläche, um solche Angriffe aus der Ferne durchzuführen.

Da der MITM-Angriff darauf abzielt, die gegenseitige Authentifizierung zu umgehen, kann ein MITM-Angriff nur erfolgreich sein, wenn der Angreifer jeden Endpunkt ausreichend gut verkörpert, um die Erwartungen zu erfüllen. Die meisten kryptografischen Protokolle enthalten eine Form der [Endpunktauthentifizierung](#), um speziell MITM-Angriffe zu verhindern. Beispielsweise kann TLS eine oder beide Parteien mit einer gegenseitig vertrauenswürdigen Zertifizierungsstelle authentifizieren. Bei SSH wird normalerweise beim Verbindungsaufbau der SSH-Server-Fingerprint überprüft und mit SSH- Server-Fingerprints von vorherigen Verbindungen zu diesem Server verglichen.

In dieser Übung führen Sie zwei Arten eines MITM-Angriffs durch: [ARP Request Poisoning](#) und [DNS Spoofing](#).

2.2 Vorbereitung der Labor-Infrastruktur

Abbildung 6 zeigt die Topologie (logische Sicht) für die Versuchsdurchführung.

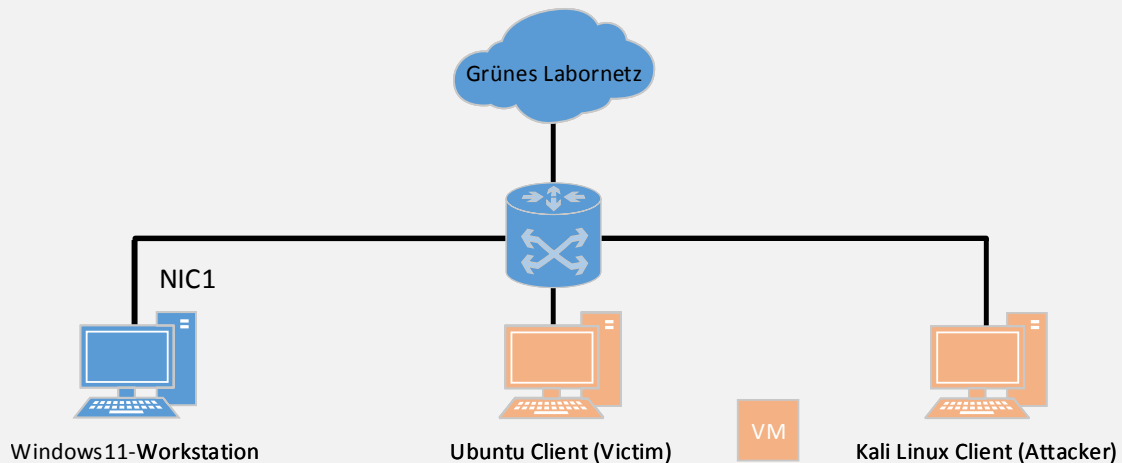


Abbildung 6: Ansicht der Topologie (logische Darstellung) *ohne* ZyXEL-Router.

Hier ist die *physische* Ansicht.

Falls ein ZyXEL-Router verwendet wird, wird dieser zwischen das Labornetzwerk und den Labor-PC mit den virtuellen Maschinen geschaltet.

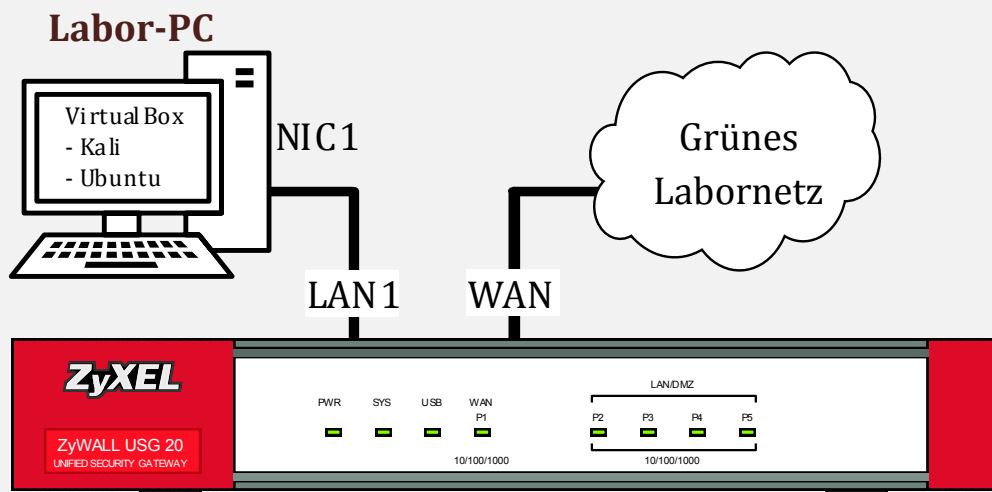


Abbildung 7: Ansicht der Topologie mit physischen Geräten *mit* ZyXEL-Router.

Falls *kein* ZyXEL-Router verwendet wird, wird der Labor-PC direkt mit dem Labornetzwerk verbunden.

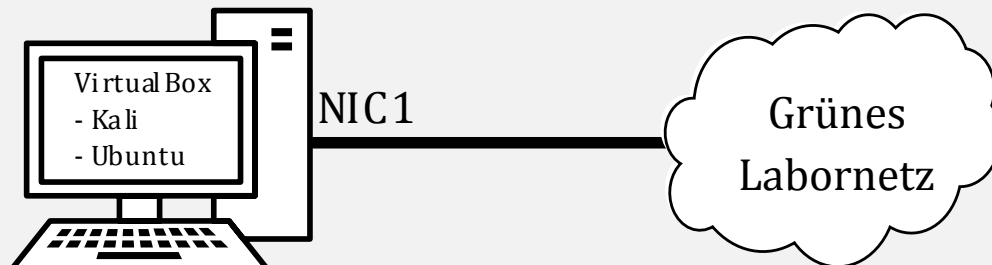


Abbildung 8: Ansicht der Topologie mit physischen Geräten *ohne* ZyXEL-Router.

Für die Versuchsumgebung benötigen Sie nur eine Windows-Workstation der Laborinsel. Diese dient als Host für die beiden VMs.

1. Verkabeln Sie Ihre Laborinsel entsprechend der physikalischen Sicht.
2. Setzen Sie die beiden VMs **Ubuntu 24.04.2** und **Kali Linux 2025.2** in **Oracle VM VirtualBox** auf dem Labor-PC in ihren Ausgangszustand zurück. Klicken Sie jeweils mit der rechten Maustaste auf den ersten Sicherungspunkt **fresh** und wählen Sie **Sicherungspunkt wiederherstellen** für jede VM.

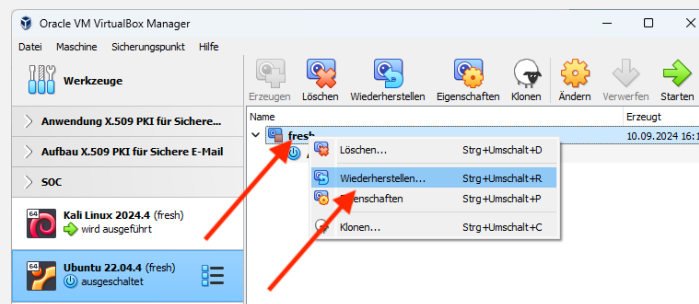


Abbildung 9: Sicherungspunkte in VirtualBox wiederherstellen vor der Bearbeitung der Aufgaben.

3. Schauen Sie je in den Settings der beiden VMs nach und vergewissern Sie sich, dass unter Netzwerk der Adapter auf Netzwerkbrücke gesetzt ist (Bridged Mode) und der richtige NIC (**NIC1** → Intel(R) Ethernet Connection (7) I219-LM) ausgewählt ist.



Mit der Einstellung Netzwerkbrücke binden Sie die VMs in das lokale Netzwerk (LAN) ein. Sie stellen also einen Verbindungspartner analog eines physischen Rechners im Netzwerk dar.

4. Starten Sie die beiden VMs `Ubuntu 24.04.2` und `Kali Linux 2025.2`.
5. In der Versuchsumgebung hat Ihr Windows-Client (der Host oder Wirt der VMs) bereits eine IP-Adresse via DHCP bezogen, bevor Sie die VMs gestartet haben. Sollten Ihrer Ansicht nach die virtuellen Maschinen die gleiche MAC-Adresse wie der Host benutzen, wenn Sie beim Startvorgang eine IP-Adresse via DHCP beziehen? Begründen Sie Ihre Antwort.

Nein. Gleiche MAC-Adressen für unterschiedliche (virtuelle und physische) Netzwerkkarten sind sehr ungünstig bis *nicht sinnvoll*. Die Kommunikation zwischen Host und VMs wäre in diesem Fall auf Ethernet-Layer nicht möglich - ausser man trifft weitere Vorkehrungen, die weit in das jeweilige Betriebssystem eingreifen.

(Würde die gleiche MAC-Adresse wie der Host verwendet werden könnte der Verkehr auf Layer 2 zwischen VM und Host nicht unterschieden werden.

Beachte: Die MAC-Adresse dient auf Layer 2 der Adressierung. Man müsste danach aufwändig am Host den Verkehr anhand weiterer Merkmale (zB. IP-Adresse) dem Host oder der jeweiligen VM zuweisen. Dies müsste der Host mit der physischen Netzwerkkarte machen.)

Die weitaus sinnvollere Lösung ist die Vergabe getrennter MAC-Adressen pro virtueller und physischer Netzwerkkarte, damit der Netzwerk-Stack auf Host und VM getrennt arbeiten kann - ohne dass dieser modifiziert werden müsste. Ansonsten würde die Kommunikation zwischen den VMs und dem Host im Layer 2 nicht funktionieren.

6. Sobald die VMs gestartet sind, checken Sie die erhaltenen IP-Adressen der Netzwerkteilnehmer: Wie lauten die IP-Adressen von Windows-Client, Ubuntu-Client und Kali Linux?

1. Bei Nutzung eines Zyxel-Routers:

- Windows-Client / Host: 192.168.1.33 -> 04:D4:C4:01:E6:2B
- kali: 192.168.1.34 -> 08:00:27:71:a6:ac
- ubuntu: 192.168.1.35 -> 08:00:27:f7:51:0f

2. Bei einem Laboraufbau *ohne* Zyxel-Router werden die IP-Adressen des Labors genutzt:

- Windows-Client / Host: 10.168.25.20 oder 10.168.25.21 -> 04:D4:C4:01:E6:2B
- kali: 10.168.25.65 -> 08:00:27:71:a6:ac
- ubuntu: 10.168.25.66 -> 08:00:27:f7:51:0f

ggf. geringfügig abweichend je nach Labor-PC



Im Dokument werden in Beispielen vorrangig IP-Adressen aus dem Netzwerk 192.168.1.0/24 genutzt. Falls Sie ein 10.168.25.0/24-Netzwerk (oder ein ähnliches) haben, müssen Sie ggf. die Befehle entsprechend ändern. Beispielsweise `nmap -sS 192.168.1.0/24` → `nmap -sS 10.168.25.0/24`.

6. Um sicher zu stellen, dass die Maschinen «sich sehen» können, pingen Sie diese von Station zu Station (zwei Pings pro Maschine).

- *Falls Sie einen ZyXEL USG20-Router haben:* Wenn die Pings funktionieren und die Stationen jeweils eine Adresse im Range 192 . 168 . 1 . 0 / 24 erhalten haben, ist Ihre Versuchsumgebung fertig eingerichtet und Sie können fortfahren.
- *Ohne ZyXEL USG20-Router:* Wenn die Pings funktionieren und die Stationen jeweils eine Adresse im Range 10 . 168 . 25 . 0 / 24 (oder ähnliche) erhalten haben, ist Ihre Versuchsumgebung fertig eingerichtet und Sie können fortfahren.

3 ARP Request Poisoning: Senden von gefälschten ARP-Paketen

Im Folgenden werden Sie ein *ARP Request Poisoning* vornehmen, um als MITM zwischen dem *Ubuntu Client* und dem *lokalen Gateway* zu interagieren. Als Angreifer benutzen Sie hierfür den Client *Kali Linux*. Um als MITM agieren zu können, müssen Sie sich zuerst eine Übersicht verschaffen, welche Hosts im Netzwerk aktiv sind. Hierzu verwenden wir an dieser Stelle das Tool *Nmap*. «Nmap ist ein Werkzeug zum Scannen und Auswerten von Hosts in einem Computernetzwerk und fällt somit in die Kategorie der Portscanner»¹.

¹ Wikipedia: <https://de.wikipedia.org/wiki/Nmap>

1. Wechseln Sie zum Kali Linux-Client und öffnen Sie ein neues Terminal.

2. Machen Sie sich kurz über das Tool *Nmap* schlau:

```
> nmap -h
```



Investieren Sie hier nicht zu viel Zeit. Sie werden sich mit *Nmap* in einem anderen Labormodul genauer auseinandersetzen.

3. Sie führen an dieser Stelle einen SYN Stealth-Scan¹ im angegebenen Netzwerk aus:

```
> nmap -sS 192.168.1.0/24
```



Zum Ausführen von *nmap* brauchen Sie *root*-Rechte: `sudo -i`.

¹ SYN Stealth-Scan, <https://nmap.org/book/synscan.html>

4. Wie viele Hosts wurden identifiziert?

4 Hosts (Firewall, Windows und 2 VMs)

5. Schreiben Sie hier die Zuordnung der jeweiligen Hosts (Windows-Client, Ubuntu-Client, Kali Linux und Gateway) zu den identifizierten IP-Adressen auf.

- GATEWAY = 192.168.1.1 (ZyXEL-Router) CC:5D:4E:33:DC:9B / open ports: ftp,ssh,dns,http,https
- Windows-Client = 192.168.1.33 (Asus) 04:D4:C4:01:E6:2B / open ports: msrpc,netbios,https,microsoft-ds,etc.
- Ubuntu-Client = 192.168.1.35 (Oracle VirtualBox virtual NIC) 08:00:27:F7:51:0F / all ports closed
- Kali Linux = 192.168.1.34 / tcp 111 open rpcbind



Probieren Sie die Zuordnung anhand der gelieferten Resultate von [Nmap](#) vorzunehmen. Interessant sind hier vor allem die offenen Ports mit den entsprechenden Diensten.

In diesem Szenario möchten Sie als MITM die Interaktion bzw. den Netzwerkverkehr zwischen Victim (identifizierter Ubuntu-Host) und Gateway mithören. Die Victim-Seite haben Sie soeben identifiziert. Falls Sie das Gateway noch nicht identifizieren konnten, dann helfen Ihnen folgende Schritte:

6. Mit folgendem Befehl wird Ihnen das lokale Gateway angezeigt:¹

```
> route -n
```

7. Wie lautet die IP-Adresse des Gateways?

192.168.1.1 (im Fall *mit* ZyXEL-Router)

¹ <https://www.computerhope.com/unix/route.htm>

Sie sollten nun beide Ziele für Ihren Angriff identifiziert haben (Gateway und Ubuntu-Client). Als nächstes werden Sie ein ARP Poisoning vornehmen, mit welchem Sie folgendes umsetzen:

Sie spielen

- dem Ubuntu Client vor, dass Sie das Gateway sind.
- dem Gateway vor, dass Sie der Ubuntu Client sind.

Dies führt dazu, dass der gesamte Traffic zwischen den beiden Zielen über Sie läuft. Entsprechend müssen Sie im Folgenden Ihren Kali Linux Client vorbereiten, damit dieser als Gateway

interagieren kann.

Um als MITM agieren und die eingehenden Pakete weiterleiten zu können (Routing), müssen Sie auf dem Linuxsystem das IP Forwarding auf Kernelebene aktivieren.

8. Öffnen Sie auf Kali Linux das Terminal.

9. Zeigen Sie sich die aktuelle IP Forwarding-Konfiguration an:

```
> sysctl net.ipv4.ip_forward
```



Der Wert 0 bedeutet, dass das IP Forwarding deaktiviert ist, 1 ist aktiviert.

10. Aktivieren Sie das **IP Forwarding**. Wechseln Sie zuvor zum «root»-User.

```
> sudo -i
```

```
> sysctl -w net.ipv4.ip_forward=1
```

Bevor Sie den Angriff ausführen, wollen wir noch ein paar Infos für den Vergleich nach dem Angriff sammeln.

11. Wechseln Sie auf die Ubuntu-Client-VM.

12. Öffnen Sie ein neues Terminal.

13. Lassen Sie sich die ARP-Tabelle zum entsprechenden Interface anzeigen:

```
> arp -a
```

14. Was ist ARP?

ARP steht für Address Resolution Protocol. Es handelt sich um ein bereits im Jahr 1982 im RFC 826 standardisiertes Protokoll. Es dient zur Verknüpfung der jeweiligen Adressinformationen auf Layer 2 (Ethernet-Layer) und Layer 3 (IP-Layer).

Soll ein Paket zu einem PC mit IP-Adresse W.X.Y.Z geschickt werden, muss im LAN das Paket zum jeweiligen PC (oder zum nächsten Router) *auf Layer 2* versendet werden. Das Versenden letztendlich erfolgt immer auf Layer 2, wenn durch Layer 3 (IP-Layer) das Netzwerk bestimmt worden ist. Dazu muss die MAC-Adresse des PCs mit der gewünschten Ziel-IP bekannt sein. ARP löst die Ziel-IP-Adresse in eine MAC Adresse auf, in dem ein Broadcast ins Subnet geschickt wird und das entsprechende Gerät mit der gewünschten IP-Adresse per ARP Response-Paket antwortet. In der ARP Response steht die MAC-Adresse der gewünschten IP-Adresse. Danach ist die MAC-Adresse bekannt und es kann ein Ethernet Frame mit der Destination MAC erstellt werden.

15. Was zeigt die Tabelle an?

Zeigt den lokalen ARP-Cache des Gerätes an. Es werden die IP-Adresse und die dazugehörige MAC-Adresse dargestellt. Die Tabelle zeigt pro Zeile die IP-Adresse, die MAC-Adresse, die Verbindungsart und das Netzwerkinterface der Geräte im Netzwerk an.

16. Wie lautet die MAC-Adresse des Gateways (für den späteren Vergleich nach dem ARP-Poisoning)?

cc:5d:4e:33:dc:9b

Im lokalen Netzwerk (LAN) kommuniziert man auf Schicht (Layer) 2 des OSI-Modells. Die Adressierung findet also über die physischen Adressen (MAC) statt. Mit dem ARP Poisoning werden Sie die MAC-Adresse im ARP-Cache (`arp -a`) des Opfers auf diejenige von Kali ändern. Heisst also, jeder Request in ein fremdes Netz (z.B. `mycampus.hs.lu.ch`) geht über Kali als Gateway!

Als Haupttask müssen Sie nun das eigentliche ARP-Poisoning auf den beiden Zielhosts vornehmen. Sie werden hierzu das Tool `arpspoof` auf Kali Linux verwenden. Es handelt sich dabei

um ein Kommandozeilenwerkzeug.

17. Machen Sie sich über das Tool schlau:

```
> arpspoof -h
```

Wie Sie sehen können, ist das Tool sehr einfach zu bedienen. Für den Angriff müssen drei der vier Optionen angegeben werden: *Interface*, *Target* und *Host*. Mit *Host* ist in diesem Kontext dasjenige Ziel gemeint, als welches man sich gegenüber dem Target ausgeben möchte. Also das Target soll einen falschen Eintrag für den Host erhalten.

18. Reicht es, den Befehl nur einmal abzusetzen, um den Angriff erfolgreich zu gestalten? Begründen Sie Ihre Antwort.

Nein, wir müssen zwei Befehle ausführen oder den Parameter `-r` (recursive) verwenden:

- `arpspoof -i eth0 -t 192.168.1.1 -r 192.168.1.35`
oder
- `arpspoof -i eth0 -t 192.168.1.1 192.168.1.35; arpspoof -i eth0 -t 192.168.1.35 192.168.1.1`

19. Führen Sie den Angriff mit `arpspoof` aus ([...] sind Platzhalter):

```
> sudo arpspoof -i [interface] -t [target] [host]
```



Wie Sie bei der obigen Frage hätten feststellen sollen, können Sie logischerweise den Befehl in umgekehrter Reihenfolge nochmals absetzen, damit auch der zweite Zielhost «vergiftet» wird und die Antwort auch über den Attacker zurückläuft. Mit der `-r`-Option kann auch nur ein Befehl abgesetzt werden (bi-direktional). Bitte beachten Sie weiter, dass das Spoofing ein kontinuierlicher Prozess ist, also beenden Sie den Vorgang auf der Konsole nicht!

20. Schauen Sie sich an, was passiert, sobald Sie den Befehl abgesetzt haben. Erklären Sie das Verhalten.

Es wird kontinuierlich ein ARP Reply an den Gateway/Router geschickt, dass die IP `192.168.1.35` die MAC-Adresse der KALI-VM besitzt. Zusätzlich wird ein ARP Reply an den UBUNTU-Client geschickt, dass die IP-Adresse `192.168.1.1` die MAC-Adresse der KALI-VM besitzt.

21. Wechseln Sie wieder auf den Ubuntu-Client.
22. Geben Sie wiederum die ARP-Tabelle aus und analysieren Sie die Ergebnisse.
Welche MAC-Adresse hat sich verändert und weshalb? Erläutern Sie in ein paar Worten, was abgelaufen ist und welche Auswirkungen der neuste Stand der Tabelle auf den Verkehr im LAN hat.

Die MAC-Adresse des Gateways 192.168.1.1 hat jetzt die MAC von KALI bekommen (08:00:27:71:a6:ac). Somit werden Pakete, die das Subnet verlassen müssen (Internet-Verkehr), zuerst an KALI geschickt werden bevor sie an den richtigen Gateway gehen.

Sie sollten sich erfolgreich als MITM platziert haben, entsprechend läuft nun der Traffic über Sie. Dann schauen Sie doch mal, was so umherfliegt.

22. Wechseln Sie wieder auf Kali Linux.
23. Öffnen Sie das Tool **Wireshark**:

```
> sudo wireshark
```

24. Starten Sie das Sniffing auf dem entsprechenden Interface.
25. Wechseln Sie auf den Ubuntu Client.
26. Setzen Sie in Firefox einen Request auf <http://dvwc.introl.ls.eee.intern/> ab. Achten Sie darauf, dass der Browser nicht automatisch zu <https://> wechselt.
27. Wechseln Sie wieder zu Wireshark und suchen Sie den GET-Request. Ist der GET-Request sichtbar? Vorzugsweise verwenden Sie hier die Filteroption für das Protokoll **HTTP** oder für **ICMP Redirects**:

```
http
```

oder

```
icmp
```



Falls Sie keine GET-Requests sehen, filtern Sie im Wireshark nach **icmp**. Sendet die ZyXEL USG20 eventuell sogar **ICMP redirect**-Pakete in das Netzwerk? Was bedeuten diese Pakete?



Beachten Sie zusätzlich, dass Sie die Seite im Firefox mehrfach neuladen müssen. Sie wird gegebenenfalls vom Firefox im Cache zwischengespeichert. Machen Sie in Firefox einfach nochmals einen Refresh mit **CTRL-F5**, um sicherzugehen.

28. Sehen Sie sich den Datenverkehr genau an. Was fällt Ihnen auf bzw. was fehlt?

Hinweis: [Netgear: What is Dynamic ARP inspection \(DAI\)?](#)

Mit ZyXEL-Router:

- Man sieht Uplink-Requests der Ubuntu-VM in das Internet. Die Downlink-Richtung (Antworten aus dem Internet) ist nicht sichtbar. Diese Pakete gehen direkt an die Ubuntu-VM, weil der ZyXEL-Router das ARP Spoofing detektiert hat.
- Im Anschluss ist im Verkehr ein **ICMP redirect**-Paket zu sehen. Dieses stammt vom ZyXEL-Router, da dieser erkannt hat, dass die IP-Pakete mit einem Umweg zu ihm gelangt sind. Generell werden ICMP-Redirects verwendet, um Umwege in einem Netzwerk zu melden, damit ein Paket möglichst ohne Umweg zum Router transportiert wird.
- Nachdem die ICMP-Redirects vom Ubuntu-Client empfangen worden sind, verschickt der Ubuntu-Client die Pakete wieder direkt an den Router und ignoriert das ARP Spoofing für diese IP-Adresse und Anfrage.
- DAI bedeutet **Dynamic ARP inspection**: DAI schützt Netzwerk-Switching-Geräte vor ARP-Paket Spoofing (ARP-Poisoning oder ARP-Cache Poisoning). DAI prüft ARPs im LAN und verwendet die Informationen einer separaten, lokalen Datenbank auf dem Switch oder Router, um ARP-Pakete zu validieren und um vor ARP Spoofing zu schützen. ARP-Anfragen und Antworten werden mit Einträgen in der Datenbank verglichen, und Filterentscheidungen werden basierend auf den Ergebnissen dieser Vergleiche getroffen. Wenn ein Angreifer versucht, ein gefaktes ARP-Paket zu versenden, um eine Adresse zu fälschen, vergleicht der Switch die Adresse mit Einträgen in seiner Datenbank. Wenn die MAC-Adresse oder IP-Adresse im ARP-Paket nicht mit einem gültigen Eintrag in der lokalen Datenbank übereinstimmt, wird das Paket verworfen. Je nach Einstellung wird zusätzlich ein ICMP-Redirect gesendet, wenn detektiert wurde, dass ein Paket über Umwege zum Router/Switch gelangt ist.

Ohne ZyXEL-Router:

- Man sieht den gesamten Verkehr - Up- und Downlink - der HTTP-Anfragen. Sowohl der TCP-Handshake als auch die HTTP-Daten sind im Wireshark einsehbar.
- DAI bedeutet **Dynamic ARP inspection**: DAI schützt Netzwerk-Switching-Geräte vor ARP-Paket Spoofing (ARP-Poisoning oder ARP-Cache Poisoning). DAI prüft ARPs im LAN und verwendet die Informationen einer separaten, lokalen Datenbank auf dem Switch oder Router, um ARP-Pakete zu validieren und um vor ARP Spoofing zu schützen. ARP-Anfragen und Antworten werden mit Einträgen in der Datenbank verglichen, und Filterentscheidungen werden basierend auf den Ergebnissen dieser Vergleiche getroffen. Wenn ein Angreifer versucht, ein gefaktes ARP-Paket zu versenden, um eine Adresse zu fälschen, vergleicht der Switch die Adresse mit Einträgen in seiner Datenbank. Wenn die MAC-Adresse oder IP-Adresse im ARP-Paket nicht mit einem gültigen Eintrag in der lokalen Datenbank übereinstimmt, wird das Paket verworfen. Je nach Einstellung wird zusätzlich ein ICMP-Redirect gesendet, wenn detektiert wurde, dass ein Paket über Umwege zum Router/Switch gelangt ist.

Sie sehen mindestens die ersten Pakete der Anfrage von der Ubuntu-VM.

- Je nachdem, ob Sie den ZyXEL USG20-Router verwenden oder nicht, unterscheiden sich die angezeigten Pakete. Falls Sie den ZyXEL USG20-Router nutzen, sehen Sie *nur* den Uplink-Verkehr von der Ubuntu-VM ins Internet. Zudem erscheinen **ICMP redirect**-Pakete, die die Ubuntu-Maschine auffordern, das ARP-Spoofing der Kali-VM zu ignorieren.
- Falls Sie den ZyXEL-Router *nicht* verwenden, sehen Sie keine **ICMP redirects**. Diese stammen nämlich vom ZyXEL-Router. Stattdessen sehen Sie sowohl den Uplink- als auch den Downlink-Datenverkehr und erkennen, dass die aufgerufene Web-Applikation im Firefox eine unverschlüsselte HTTP-Verbindung aufbaut. Daher sollten Sie den gesamten Traffic im Klartext einsehen können.

29. Probieren Sie sich am **DVWC** mit *irgendwelchen* Credentials anzumelden.
30. Wechseln Sie wieder zu **Wireshark** und suchen Sie nach den POST-Requests für das Login.
31. Finden Sie die Credentials im Klartext?

Ja, HTTP POST /login HTTP/1.1: Die Credentials findet man in der HTML-Form im Klartext.

Heutzutage ist es für einen Angreifer nicht mehr so einfach, Traffic im Klartext mitzulesen, da viele Seiten über HTTPS laufen. Wie dies in Wireshark aussieht, schauen wir uns im Folgenden an.

32. Rufen Sie über Firefox auf dem Ubuntu Client die Seite `mycampus.hs.lu.ch` auf.
33. Probieren Sie sich mit irgendwelchen Credentials anzumelden.

Um den HTTPS-Verkehr in Wireshark zu finden, verwenden Sie wiederum Filteroptionen. Um dies möglichst einfach vorzunehmen, benötigen Sie die IP-Adresse des Servers von `mycampus.hs.lu.ch` wie auch das Protokoll und den Port für den HTTPS-Traffic.

34. Über welches Protokoll und welchen Port läuft der HTTPS-Traffic?

- Ethernet / IP / TCP / HTTPS + TLS: Transport Layer Security
- Port: 443

35. Um die IP-Adresse des Webserver herauszufinden, verwenden Sie das Tool `nslookup`¹. Geben Sie im Terminal auf Kali Linux folgenden Befehl ein:

```
> nslookup mycampus.hs.lu.ch
```

¹ <https://de.wikipedia.org/wiki/Nslookup>

36. Wie lautet die IP-Adresse des Webserver?

```
147.88.201.69
```

Mit diesen Informationen können Sie nun in Wireshark entsprechend filtern.

38. Geben Sie im Filterfeld folgende Zeichen ein ([...] sind Platzhalter):

```
[Protokoll].port == [Portnummer] && ip.dst == [IP-Adresse  
Webserver]
```

39. Schauen Sie sich den gefilterten Traffic an und werfen Sie einen Blick auf die TLS-Pakete mit der Info «Application Data».



Wenn Sie einen Blick in die Pakete werfen, können Sie zuerst den TCP Handshake sehen. Danach wird der TLS Handshake abgehandelt. Da Sie mindestens den Beginn des Uplink-Verkehrs sehen, sollten möglicherweise Pakete wie `Client Hello` oder `Application Data` zu sehen sein. Schlussendlich finden Sie im Folgepaket unter dem Reiter Transport Layer Security die verschlüsselten Applikationsdaten. Der GET-Request kann *nicht* im Klartext eingesehen werden, da der Verkehr verschlüsselt ist.

Für weiterführende Massnahmen, um beispielsweise Credentials und den Traffic über eine HTTPS-Verbindung mitlesen zu können, benötigt es allerdings weitere Massnahmen. Im nächsten Kapitel zu DNS Spoofing führen Sie einen Angriff durch, um an die Credentials eines Users auf MyCampus zu gelangen.

Zusammenfassung

Sie verstehen, wie Angreifer `ARP Spoofing` nutzen, um Datenverkehr umzuleiten.

- Sie verstehen den Ablauf einer Man-in-the-Middle-Attacke mit `ARP Spoofing`. Bei einer `ARP Spoofing-Attacke` sendet der Attacker gefälschte ARP-Pakete in das Netzwerk und gibt sich als Gateway und Opfer aus, sodass er/sie den Verkehr in beide Richtungen mitlesen kann.
- Bei Kali Linux können Sie dafür das Tool `arpspoof` verwenden.
- Sie können eine solche Attacke analysieren und kennen die Tools `nmap`, `arp` und `route`. Mit dem Tool `Wireshark` können Sie den Verkehr analysieren und verstehen. Mit dem Befehl `sysctl -w net.ipv4.ip_forward=1` können Sie einen Linux-PC veranlassen als Router zu agieren, um Pakete weiterzuleiten.

In unserem Fall sehen Sie mindestens die ersten Pakete - auch, wenn Router Massnahmen zum Verhindern des Spoofings treffen. Unter anderem untersucht der ZyXEL USG20-Router die ARP-Requests im Netzwerk und verhindert das Weiterleiten der Pakete in Richtung Downlink zur Kali-VM. Weiter sendet der Router `ICMP Redirect`-Informationen im Netzwerk an Clients, falls er einen Umweg der Pakete im Netzwerk detektiert.

- Sie verstehen, welche Massnahmen Router gegen `ARP Spoofing` ergreifen können.
- Sie kennen das Feature `Dynamic ARP inspection (DAI)`.

4 DNS Spoofing: Fehlerhafte Domain-Name-System-Einträge im Zwischenspeicher (Cache) des DNS-Resolvers eingeben

Im Folgenden werden Sie aufbauend auf dem ARP Request Poisoning ein DNS Spoofing vornehmen. Dabei nehmen Sie `mycampus.hs-lu.ch` als Ziel ins Auge. Ziel dabei ist es, die Credentials (UN/PW) eines Users - hier vom Benutzer des Ubuntu Clients - zu ergattern. Für diesen Versuch wird auf Kali Linux mit den Tools `Ettercap` und `httrack` gearbeitet. Mit `Ettercap` wird die Man-in-the-Middle-Attacke durch ARP Request Poisoning und DNS Spoofing durchgeführt. Das Tool `httrack` ist ein Website-Kopierer. Dieser kopiert eine Website, indem er die Links verfolgt und die Dateien herunterlädt. Folgen Sie den anschliessenden Schritten genau, um das System entsprechend für den Angriff zu konfigurieren.

1. Lassen Sie auf Kali Linux das `ARP Request Poisoning` weiterlaufen. Falls Sie das/die Terminal/s schon geschlossen haben, dann starten Sie das ARP Request Poisoning wieder und öffnen Sie zusätzlich ein zusätzliches Terminal / einen neuen Tab.

Um `Ettercap` vernünftig benutzen zu können, müssen Sie sich die entsprechenden Rechte erteilen. Diese werden in der Datei `etter.conf` festgelegt. Die entsprechenden Attribute lauten `ec_uid` und `ec_gid`.

2. Was bedeuten die beiden Begriffe UID und GID in der Linuxumgebung und welchen Zweck erfüllen Sie?

User ID, Group ID; Sie werden für die Identifikation und Rechtevergabe unter Linux verwendet.

3. Wie lauten die `UID` und `GID` für den User `root`?

UID: 0 & GID: 0



Hilfestellung finden Sie unter https://learning.lpi.org/de/learning-materials/010-160/5/5.1/5.1_01/.

4. Öffnen Sie die Datei `etter.conf`.

```
> sudo nano /etc/ettercap/etter.conf
```

5. Um sich entsprechende Rechte/Privilegien zu erteilen, setzen Sie am Anfang der Datei bei `ec_uid` und `ec_gid` den Wert für Rootrechte.

6. Nun müssen Sie noch `iptables` aktivieren, damit das IP-Forwarding auch entsprechend funktioniert und Sie als MITM agieren können. Hierzu suchen Sie mit «CTRL-W» nach «`iptables`». Die Konfiguration ist in der Datei schon korrekt definiert. **Sie müssen nur noch die Auskommentierung entfernen.** Entfernen Sie die Kommentarzeichen `#` in den vier `redir_command`-Zeilen unterhalb des Titels `Linux`.

7. Schauen Sie sich die `iptables`-Rules an.

8. Erklären Sie kurz, was diese bewirken.

Der das `Ettercap`-Programm (Proxy) hört auf einem Port (`%rport`) und nimmt dort Anfragen entgegen. Damit gespoofter Verkehr, der bei der Kali-VM ankommt durch den Proxy geleitet werden kann, werden IP-Pakete mit Port `%port` an sich selbst den `Ettercap`-Port (`%rport`) weitergeleitet (`-d %destination --dport %port -j REDIRECT --to-port %rport`). Mit `-A` kann diese Regel aktiviert werden (anhängen an den Regelbaum) und mit `-D` kann diese wieder entfernt werden. Die Regeln entsprechen also einem Redirect auf den lokalen `Ettercap` service.

9. Damit ist die Konfiguration in der Datei `etter.conf` abgeschlossen. Speichern Sie die Änderungen und schliessen Sie den Editor. (`CTRL-S` zum Speichern, `CTRL-X` zum Verlassen)

Für das DNS Spoofing möchten Sie das Opfer bei Eingabe der URL `mycampus.hs.lu.ch` auf Ihren (malicious) Webserver mit der gefälschten Login-Webseite leiten. Hierzu müssen Sie die entsprechenden Einstellungen in der Datei `etter.dns` vornehmen.

10. Was ist mit DNS Spoofing gemeint? Machen Sie sich allenfalls im Web schlau.

Der DNS Cache eines Clients oder Servers wird mit falschen Einträgen gespickt. Also eine Auflösung eines DNS-Namens geht jetzt plötzlich auf die falsche IP-Adresse.

11. Öffnen Sie die Datei `etter.dns` mit dem Editor `gedit` oder `nano`:

```
> sudo nano /etc/ettercap/etter.dns
```

12. Studieren Sie die Beispieleinträge und überlegen Sie sich was Sie eintragen müssten. Sie wollen ein Redirecting für die Domain `hs.lu.ch` bzw. Subdomain `mycampus.hs.lu.ch` machen.

13. Fügen Sie die folgenden fünf Zeilen für das Redirecting am Ende der Datei an, damit der Nameserver die IP der Kali VM liefert. Vergessen Sie nicht die IPs anzupassen.

```
mycampus.hslu.ch      A      192.168.1.[x]
mycampus.hslu.ch      AAAA    [IPv6-Adresse(link-local)]
*.mycampus.hslu.ch    A      192.168.1.[x]
*.mycampus.hslu.ch    AAAA    [IPv6-Adresse(link-local)]
www.mycampus.hslu.ch PTR     192.168.1.[x]
```



Vergessen Sie nicht beim Code-Fragment zuvor die entsprechenden Ersetzungen zu machen, siehe [...]. Schauen Sie sich die Einträge vom Code-Fragment genau an.



Tragen Sie auch die Einträge für IPv6 ein, damit das Spoofing ordnungsgemäss funktioniert.

14. Für was stehen **A**, **AAAA** und **PTR**?

- **A** = Host Eintrag (IPv4)
- **AAAA** = Host Eintrag IPv6
- **PTR** = Pointer Eintrag (Verknüpfung)

15. Weshalb werden hier auch die **AAAA**-Records erfasst? Was könnte (im produktiven Einsatz) schief laufen, wenn nur die **A**-Records vorhanden wären (im Versuch allerdings nicht relevant → link-local only)?

Falls IPv6 genutzt wird → nötig: Wird der DNS-Server über IPv6 angefragt und es ist ein IPv6-Eintrag vorhanden, so wird die Kommunikation über IPv6 erfolgen. Somit wären unsere Einträge mit nur A-Records (=IPv4) sinnlos. Es werden auch IPv6-Einträge benötigt, damit alles auch bei IPv6 funktioniert.

16. Speichern Sie das File und schliessen Sie es.

Damit der Versuch wunschgemäß klappt, leeren Sie noch den DNS-Cache auf dem Ubuntu Client wie auch im Browser. Andernfalls kann es sein, dass nicht die gewünschte Seite aus dem Zwischenspeicher geladen wird.



Der DNS-Cache wird hier manuell auf dem Opfersystem geleert. Dies soll Ihnen die Hürden für so einen Angriff aufzeigen. Bei einem produktiven Angriff könnte die Thematik trotzdem gelöst werden. Wie Sie in späteren Modulen erfahren, kann beispielsweise per Reverse Shell auf die Konsole des Opfersystems zugegriffen und so die gleichen Kommandos abgesetzt werden. Ausserdem gilt es zu erwähnen, dass für die Einträge im DNS-Cache bei Firefox standardmässig eine Expiration Time von 60 Sekunden gesetzt ist. Bei Chrome sind es 30 Sekunden.

Zuerst löschen wir den DNS-Cache auf dem Ubuntu-OS. Geben Sie dazu folgende Befehle ein:

18. Zuerst schauen Sie sich die Cache-Einträge mal an:

```
> resolvectl statistics
```

19. Anschliessend löschen Sie den Cache:

```
> sudo resolvectl flush-caches
```

20. Prüfen sie mit `resolvectl statistics`, ob die Grösse des Cache jetzt 0 ist. Falls nicht, wiederholen sie das Flushen des Cashe.

21. Nun müssen Sie noch den DNS-Dienst neu starten:

```
> sudo systemctl restart systemd-resolved
```

22. Lassen Sie sich nochmals die Einträge anzeigen und vergewissern Sie sich, dass der Cache leer ist.

Nun löschen Sie noch den Cache bzw. den Verlauf im Firefox Browser.

23. Betätigen Sie folgende Tastenkombination.

```
> Ctrl + Shift + H
```

24. Klicken Sie beim Eintrag von **MyCampus** die rechte Maustaste und wählen Sie **Forget about this site/Gesamte Website vergessen**.

25. Schliessen Sie den Browser.



Sie schliessen den Browser, da er nach genaueren Untersuchungen noch auf den schon gelöschten Cache zugreift, wenn er nicht geschlossen wird. Heisst also, die Änderungen ziehen erst nach einem «Neustart» von Firefox.

26. Öffnen Sie auf dem Ubuntu Client **Wireshark** auf der Konsole:

```
> sudo wireshark
```



Sie werden die nächsten Schritte in Wireshark aufzeichnen, damit Sie später die Funktionsweise des ARP und DNS Spoofing nachvollziehen bzw. den Traffic betrachten können.

27. Starten Sie auf dem entsprechenden Interface eine neue Aufzeichnung.

28. Starten Sie nun **Ettercap** auf Kali Linux über folgendes Kommando:

```
> sudo ettercap -G
```

29. Vergewissern Sie sich, dass unter Primary Interface das korrekte Interface ausgewählt ist.

30. Klicken Sie links in der Tableiste auf den Häkchen (Accept).



Sie stoppen hier das Sniffing gleich wieder, da Sie zuerst noch ein paar Einstellungen vornehmen werden.

31. Klicken Sie links auf die neu erschienene Lupe für **Scan for hosts**.



Ettercap identifiziert für Sie die Hosts im Netzwerk, analog zu Nmap beim ARP Poisoning.

32. Wählen Sie die **Hosts List** aus, direkt neben der Lupe.

Sie sehen nun die aufgelisteten Hosts im Netzwerk. Diese werden Sie nun als Ziele definieren.

33. Wählen Sie das Gateway als Target 1:

```
Add to Target 1
```

34. Wählen Sie den Ubuntu Client als Target 2:

```
Add to Target 2
```

35. Führen Sie das ARP Request Poisoning über **Weltkugelsymbol** → **ARP poisoning** ... aus.

36. Wählen Sie nur **Sniff remote connections** aus.



Sie haben im Hintergrund immer noch das ARP Request Poisoning mit dem Tool `arp spoof` am Laufen. Grundsätzlich macht hier `Ettercap` genau dasselbe, jedoch nicht ganz so effizient. Die Frequenz der sendenden ARP-Pakete ist geringer als bei `arp spoof` und kann alleine zu Ausfällen führen. Deshalb «bombardieren» Sie hier den Ubuntu Client mit beiden Tools.

37. Wählen Sie in `Ettercap` über den mit drei vertikalen Punkten versehenen Button `Plugins` → `Manage plugins` aus.

38. Wählen Sie das Plugin `dns_spoof` per Doppelklick aus.



Mit dem Plugin aktivieren Sie die von Ihnen vorgenommenen Einstellungen in `etter.conf` und `etter.dns`.

39. Starten Sie im Terminal noch den Apache Webserver:

```
> service apache2 start
```

40. Checken Sie wiederum auf dem Ubuntu Client, ob das ARP Poisoning funktioniert bzw. immer noch funktioniert.

41. Wie prüfen Sie dies schon wieder?

Auf dem Ubuntu Client:

```
> arp -a
```



Wenn das DNS Spoofing funktioniert, dann wird der Request auf `mycampus.hs.lu.ch` vom Ubuntu Client auf Ihren «malicious» Webserver umgeleitet.

42. Testen Sie kurz, was passiert, wenn Sie auf dem Ubuntu Client den folgenden Befehl absetzen:

```
> nslookup mycampus.hs.lu.ch
```

43. Was ist der Zweck bzw. die Funktionsweise von `nslookup`? Erklären Sie den Output.

nameserver lookup: Auflösung von `mycampus.hs.lu.ch` zu der dazugehörigen IP-Adresse. Es wird der konfigurierte DNS Server angefragt.

44. Auf welche IP-Adresse wurde `mycampus.hs.lu.ch` aufgelöst? Was bedeutet dies für den Ubuntu Client und Sie als Angreifer?

192.168.1.34 ← KALI; Anfragen über den Ubuntu Client auf `mycampus.hs.lu.ch` landen jetzt auf der Kali VM.

45. Testen Sie auf der Konsole des Ubuntu Client noch folgende Befehle:

```
> host mycampus.hs.lu.ch
> dig mycampus.hs.lu.ch
> ping mycampus.hs.lu.ch
```

46. Öffnen Sie nun den Browser neu (Firefox) und gehen Sie auf `mycampus.hs.lu.ch`.

47. Was sehen Sie?

Apache2 Debian Default Page

48. Wechseln Sie nun zu Wireshark auf dem Ubuntu Client. Wie Sie sich erinnern, hatten Sie dort eine Aufzeichnung gestartet.



Wir wollen nun das ARP wie auch DNS Spoofing im aufgezeigten Traffic nachvollziehen können.

49. Zuerst schauen Sie sich das ARP Request Poisoning an. Verwenden Sie hierzu den Protokollfilter:

`arp`

50. Beschreiben Sie hier kurz, was Sie sehen bzw. was hier passiert ist.

ARP-Replies erreichen Ubuntu, weil 192.168.1.1 zu 08:00:27:71:a6:ac gehört.

51. Nun schauen Sie sich noch das DNS Spoofing an. Verwenden Sie hierzu einen Filter, welcher die DNS-Anfrage anzeigt:

`dns.qry.name==mycampus.hs.lu.ch`

52. Beschreiben Sie hier kurz was Sie sehen bzw. was hier passiert ist.

Es ist eine DNS-Standard-Query mit der Anfrage nach `mycampus.hslu.ch` an 192.168.1.1 zu sehen; Response kommt von 192.168.1.1 mit der IP 192.168.1.34.

53. Schauen Sie sich noch den Output im Tool `Ettercap` auf Kali Linux an.

Wenn alles reibungslos funktioniert hat, sollten Sie nun die Landing Page des Apache Webserver sehen. Das heisst, dass der Ubuntu Client - das Opfer - momentan auf dieser Seite landet, wenn er auf MyCampus zugreifen möchte. Dieses Szenario bringt Ihnen entsprechend keinen Nutzen. Im Folgenden werden Sie Ihre Landing Page so einrichten, dass eine Kopie der MyCampus-Anmeldeseite angezeigt wird und das Opfer entsprechend getäuscht werden kann. Das Ziel ist es, dass ein naiver User seine Credentials auf der malicious Login-Webseite eingibt und Sie diese abfangen können.

4.1 Aufsetzen des *malicious* Webservers

Im letzten Abschnitt jubeln Sie dem Opfer eine gefälschte Anmeldeseite unter und leiten es danach auf eine Fehlermeldung mit der Bitte um Geduld. Wir wählen für das fiktive Beispiel natürlich keine Bank, sondern die MyCampus-Seite, wo bestenfalls ECTS-Punkte zu holen sind. :-)

Wir haben Ihnen die Login-Webseite von <https://mycampus.hslu.ch> bereits mit dem Tool `httrack` kopiert. Dies deswegen, da allenfalls unser Zugriff vom Labor gesperrt werden würde, falls alle gleichzeitig mit dem Tool auf MyCampus schiessen.

Die Schritte für das Kopieren einer Seite mit `httrack` sind im Folgenden trotzdem kurz aufgeführt, damit Sie den Vorgang nachvollziehen können. **Wir bitten Sie aber, nicht nochmals die Seite zu kopieren, aus oben genannten Gründen.**

Kali bietet von Haus aus einen Apache Webserver. Das Document-Rootverzeichnis befindet sich in `/var/www/html`. Standardmässig ist dort schon eine Indexdatei abgelegt. Diese haben Sie auch schon im Browser gesehen.



Wie Ihnen vielleicht aufgefallen ist, wird seit neuem MFA für die Anmeldung bei mycampus.hslu.ch verwendet. Dies ist eine sehr gute Massnahme gegen diesen Angriff, welche zu überwinden einen signifikanten Aufwand bedeutet.



Führen Sie die folgenden Schritte **nicht** aus. Sie dienen lediglich zur Dokumentation. Diese Schritte zeigen, wie die Website durch `httrack` kopiert wurde:

1. Sie können sich die Hilfestellung ansehen, um die Optionen des Kommandozeilentools kennenzulernen.

```
> httrack -h
```

2. Die Syntax für das Kopieren einer Website lautet folgendermassen.

```
> httrack [the URL oft the site] [any options] URL  
Filter -O [location to send copy to]
```

3. Folgender Befehl kopiert die Seite.

```
> httrack https://mycampus.hslu.ch -O /var/www/html/  
httrack_mycampus
```

Fahren Sie ab hier mit der Ausführung des Versuchs weiter.

1. Wechseln Sie zu einer Root-Shell mit Administratorrechten.

```
> sudo -i
```

2. Wechseln Sie in das Document-Rootverzeichnis von Apache:

```
> cd /var/www/html/
```

3. Löschen Sie die aktuelle index.html-Datei:

```
> rm index.html
```

4. Laden Sie die vorbereiteten MyCampus Dateien mittels wget herunter:

```
> wget "https://drive.switch.ch/index.php/s/JPG4PpVMxMQUnYi/download" -O httrack_mycampus.zip
```

5. Entpacken Sie das heruntergeladene ZIP-Archiv:

```
> unzip httrack_mycampus.zip
```

6. Laden Sie im Firefox auf Kali Linux die Seite `localhost`. Sie müssten nun die kopierte Login-Webseite von MyCampus sehen. Wenn Sie allerdings genau hinsehen, erkennen Sie eine andere URL.

7. Wieso lautet die URL `http://localhost/mycampus.hslu.ch/de-ch/index.html` und wohin wurden demnach die Dateien von `httrack` kopiert?

Die Dateien wurden in den Apache2-Standard-Ordner heruntergeladen. Wir greifen direkt auf den lokalen Webserver zu.

Offenbar findet zuerst noch eine kurze Umleitung auf die eigentliche Login-Webseite statt. Dies ist unschön und wir beheben das, damit ein potenzielles Opfer den Braten nicht riecht.

8. Öffnen Sie in Kali Linux den Filemanager als `root`.

```
> sudo xdg-open .
```

9. Wechseln Sie in das Verzeichnis `/var/www/html`.

10. Löschen Sie alle Dateien in diesem Verzeichnis, **nicht aber** den Ordner `mycampus.hslu.ch`. Die nun gelöschten Dateien werden standardmässig von `httrack` angelegt und erledigen die Umleitung. Die kopierte Login-Webseite befindet sich im Unterordner `mycampus.hslu.ch`.

11. Wechseln Sie in den Unterordner `mycampus.hs.lu.ch` und verschieben Sie seinen ganzen Inhalt (Dateien und Ordner) eine Ebene höher nach `/var/www/html/`.
12. Löschen Sie den nun leeren Unterordner `mycampus.hs.lu.ch` in `/var/www/html/`.



Die eigentliche MyCampus Seite befindet sich in den Ordnern `de-ch` (Deutsch) respektive `en` (Englisch).

13. Öffnen sie als nächstes die Datei `index.html` welche sich im Ordner `/var/www/html` befindet:

```
> nano index.html
```

Wie Sie sehen, ist diese von `httrack` generierte Datei für die Weiterleitung nach `de-ch/index.html` verantwortlich. Leider erscheint aber noch die Meldung «Click here...». Dies wollen wir nun ändern.

14. Entfernen Sie den kompletten Body der geöffneten `index.html`-Datei, also von `<BODY>` bis und mit `</BODY>` und speichern Sie die Datei ab. (Mit `CTRL-K` können Sie ganze Zeilen in `nano` löschen.)

4.2 Anpassen der kopierten und malicious Login-Webseite

Momentan wird das Formular für die Anmeldemaske noch an den Originalserver von MyCampus gesendet. Testen Sie dies kurz:

1. Machen Sie auf Kali Linux (`http://localhost`) einen Anmeldeversuch bei MyCampus mit beliebigen Credentials.
2. Wo landen Sie nach dem Absenden des Formulars?

Auf der richtigen, tatsächlichen Loginmaske auf `https://mycampus.hs.lu.ch/de-ch` und nicht auf unserer gefakten, kopierten Seite. Man wird nach Absenden der Credential auf die richtige URL `https://mycampus.hs.lu.ch/de-ch` weitergeleitet.

Sie werden nun die Dateien bzw. das Formular so anpassen, dass nach Absenden der Logindaten eine Weiterleitung auf die zu präparierende Wartungsseite stattfindet.

3. Wechseln Sie in das Verzeichnis der kopierten Login-Webseite:

```
> cd /var/www/html/de-ch
```


4. Öffnen Sie mit dem Editor `nano` die Datei `index.html`:

```
> nano index.html
```

5. Suchen Sie den Formularanfang im HTML-Dokument:

6. `CTRL-W` mit Suchbegriff `<form`.



Wie Sie wissen, sendet ein HTML-Formular die Daten beim `Submit` an die im Attribut `action` definierte Adresse.

7. Ändern Sie das Attribut entsprechend ab:

```
> action="http://mycampus.hslu.ch/de-ch/wartung.html"
```

8. Speichern Sie die Datei und schliessen Sie sie.

9. Öffnen Sie auf der Kali-VM `Wireshark` und starten Sie eine neue Aufzeichnung.

10. Wechseln Sie nun zum `Ubuntu Client`.

11. Prüfen Sie, ob das ARP Request Poisoning noch auf dem `Ubuntu Client` aktiv ist:

```
> arp -a
```

12. Wenn nicht, führen Sie es mit `arpspoof` und `ettercap` auf der Kali-VM nochmals aus.

13. Prüfen Sie auf dem Ubuntu Client, ob es funktioniert:

```
> nslookup mycampus.hslu.ch
```

14. Öffnen Sie den Browser auf dem `Ubuntu Client` und gehen Sie auf die Seite `mycampus.hslu.ch`. Falls sie falsch weitergeleitet werden müssen Sie den Browsercache leeren: `Burger-Menü > Settings > Privacy & Security > Clear Data`.

15. Was könnte einem potentiellen Opfer bei der Wartungsseite auffallen?

HTTP (kein HTTPS) → Zertifikatswarnung im Browser.

16. Probieren Sie sich anzumelden.

17. Wo landen Sie nach dem Absenden des Formulars laut URL im Browser? Versucht der Browser, eine HTTP- oder HTTPS-Verbindung aufzubauen?

Es wird versucht unsere Wartungsseite `http://mycampus.hslu.ch/de-ch/wartung.html` zu öffnen. Nun wird aber endlich *nur* ← HTTP (kein HTTPS) genutzt, da die `action`-Anweisung von uns geändert wurde.

18. Suchen Sie die Credentials in Wireshark. Sie sollten Sie im Klartext sehen.

19. Welche zwei Punkte fallen auf, dass es sich bei der Seite um eine Fälschung handelt?

- Die Zertifikatswarnung und die Meldung der Wartung auf der Seite.
- Das Passwort findet man im POST Request zu `/de-ch/wartung.html`:
Form item: `ph_campus_content_main_part` → Username und im nächsten Form item: das Passwort.

Zusammenfassung

- Sie haben **Domain Name System (DNS) Spoofing** analysiert und durchgeführt.
- Sie können das Tool **Ettercap** anwenden und verstehen, was es tut.
- Sie verstehen den Ablauf eines Man-in-the-Middle-Angriffs mit **DNS Spoofing**. Sie wissen, wie Angreifer eine Website klonen und damit die Anmeldeinformationen eines Benutzers abfangen können.
- Sie haben Anzeichen dafür kennengelernt, dass eine Website gefälscht sein könnte.

DNS Spoofing oder **DNS Cache Poisoning** ist ein Angriff, bei dem DNS-Anfragen abgefangen und DNS-Einträge beim Opfer mit Hilfe von gefakten DNS-Antwortpaketen manipuliert werden. Damit wird das Opfer auf eine betrügerische, bösartige Website umgeleitet, die dem beabsichtigten Ziel des Opfers ähnelt.

Ettercap ist eine freie Software zur Durchführung von Man-in-the-Middle-Angriffen. Es unterstützt Sniffing von ARP- und IP-Paketen, ARP Poisoning, Echtzeitkontrolle über Verbindungen, inhaltsbasierte Filterung sowie aktive und passive Analyse einzelner Hosts und ganzer Netzwerke. DNS Spoofing wird mit der Datei `/etc/ettercap/etter.dns` konfiguriert und mit der Datei `/etc/ettercap/etter.conf` aktiviert.

ENDE

Laden Sie das ausgefüllte PDF mit Hilfe des vorbereiteten Abgabeordners in ILIAS hoch.

